```
    "tools": [
      {
        "vendor": "anchore",
        "name": "syft",
        "version": "v0.46.3"
      }
    ],
    "component": {
      "bom-ref": "3c49c5c51b864d3e",
      "type": "container",
      "name": "oshi36/nodeapp_test:latest",
      "version": "sha256:d1e152be03b2b120ffd969eb276d59876ae6
e7e91510915d6080f0b5c36f1f02"
    }
  },
. . . .
docker sbom oshi36/nodeapp_test:latest –format syft-json
```

It outputs the SBOM report in Syft's native JSON format:

```
{
 "artifacts": [
  {
   "id": "2a0a99c2a38a6407",
   "name": "JSONStream",
   "version": "1.3.5",
   "type": "npm",
   "foundBy": "javascript-package-cataloger",
   "locations": [
    {
     "path": "/usr/local/lib/node_modules/npm/node_modules/
JSONStream/package.json",
     "layerID": "sha256:8ca4f4055a7095ff1807ce521287ae7bdd91a
a711ae45d5b0f3d1c45ab0adefe"
    }
   ],
   "licenses": [
    "(MIT OR Apache-2.0)"
   ],
   "language": "javascript",
   "cpes": [
    "cpe:2.3:a:JSONStream:JSONStream:1.3.5:*:*:*:*:*:*:*",
    "cpe:2.3:a:*:JSONStream:1.3.5:*:*:*:*:*:*:*"
   ],
   "purl": "pkg:npm/JSONStream@1.3.5",
   "metadataType": "NpmPackageJsonMetadata",
   "metadata": {
    "name": "JSONStream",
    "version": "1.3.5",
    "author": "Dominic Tarr <dominic.tarr@gmail.com> (http://
bit.ly/dominictarr)",
    "licenses": [
     "(MIT OR Apache-2.0)"
    ],
. . . .
```

Log4j 2 vulnerability use case

Log4j 2 is a logging library by Apache and its vulnerability CVE-2021-44228 allows remote code execution from a context that is easily available to an attacker. This vulnerability has been found in Minecraft servers. It allows commands to be typed in chat logs and then sent to the logger.

Currently, CVE-2021-44228 impacts all versions of Log4j 2.x <= 2.14.1. If the container image has Log4j, then *docker sbom* can help in finding out its version and deciding whether it's vulnerable or not.

- To list the components of jboss/wildfly application server and find whether its Log4j version is vulnerable or not, type:

```
docker sbom jboss/wildfly | grep log4j
```

From the output given below it can be seen clearly that Log4j is vulnerable to CVE-2021-44228 due to its version:

```
docker sbom jboss/wildfly | grep log4j
Syft v0.46.3
✔ Pulled image
✔ Loaded image
✔ Parsed image
✔ Cataloged packages      [1151 packages]
log4j-api
2.14.1                    java-archive
log4j-jboss-logmanager
1.2.2.Final               java-archive
log4j2-jboss-logmanager
1.0.0.Final               java-archive
```

To sum up, *docker sbom* helps in generating the SBOM for the container image, which helps identify and solve any dependency issues. END

By: Oshi Gupta

Oshi Gupta works as a DevOps engineer and technical writer at CloudYuga Technologies. She loves writing blogs and is keen to learn about various cloud native technologies.